

Narrativa explicativa de la Encuesta COBIT 2019 de Ciberseguridad

1. Por qué otra encuesta... y por qué ésta

La ciberseguridad se ha convertido en el deporte de riesgo corporativo por excelencia: todos dicen practicarlo, pocos entrenan en serio. La propuesta de esta encuesta no es añadir otro formulario más a la pila, sino **poner orden en el caos** usando COBIT 2019 como esqueleto intelectual.[web:18][web:39]

COBIT aporta una tradición robusta de **gobierno y gestión de TI** con procesos claros, objetivos bien definidos y una obsesión saludable por la medición.[web:18][web:29] En su versión 2019, además, incorpora áreas de enfoque específicas, entre ellas la **seguridad de la información**, que nos proporcionan el vocabulario perfecto para hablar de ciberseguridad sin caer ni en el tecnicismo críptico ni en el humo motivacional.[web:21][web:44]

Esta encuesta pretende, sencillamente, hacer visibles las costuras: qué se gobierna, qué se gestiona, qué se mide... y qué se finge.

2. La lógica COBIT por debajo de las preguntas

Cada bloque del cuestionario responde a un conjunto de **objetivos COBIT**:

- Gobierno y riesgo: EDM03.
- Gestión del riesgo de TI: APO12.
- Seguridad gestionada / SGSI: APO13.
- Cambios de TI: BAI06.
- Servicios de seguridad (SOC, respuesta, vulnerabilidades): DSS05.
- Continuidad: DSS04.
- Monitorización, auditoría y cumplimiento: MEA01-03.[web:18][web:21]

No se trata de preguntar “si tiene firewall” o “si aplica tal norma”, sino de evaluar si esos controles viven dentro de un **sistema coherente de gobierno y gestión**. En otras palabras: si la ciberseguridad es una colección de gadgets o una disciplina de gestión.

3. De los ítems de encuesta a los indicadores

Cada pregunta del cuestionario se ha diseñado para alimentar uno o más **indicadores cuantificables**:

- Frecuencia de revisión por el órgano de gobierno → indicador de alineamiento estratégico.
- Cobertura de análisis de riesgos → indicador de gestión de riesgo de TI.
- Grado de formalización del SGSI → indicador de madurez de seguridad.
- Porcentaje de cambios con evaluación de seguridad → indicador de seguridad en el ciclo de vida de TI.
- Niveles de MTDD/MTTR → indicador de desempeño operativo de los servicios de seguridad.
[web:44][web:46]

A partir de esas piezas, se construye el **Índice Global de Madurez (IGM)** y otros indicadores derivados de ROI y resiliencia, cuyos modelos de cálculo se dejan listos para implementar.

4. El equilibrio entre rigor y honestidad

La encuesta no es un examen de certificación ni un ritual de autoelogio. Está pensada para que una organización pueda:

- Reconocer su situación real con cierta elegancia.
- Identificar brechas concretas respecto a un marco reconocido.
- Priorizar acciones de mejora con sentido de negocio.

Las opciones de respuesta, a veces con un punto de ironía, ayudan a situarse en la escala sin necesidad de leer un tratado de semántica. Si una organización se ve reflejada en la opción “rezamos” o “los simulacros solo ocurren en producción”, no es para señalarla con el dedo, sino para ofrecerle un espejo bien pulido.

5. Uso estratégico de los resultados

Los resultados agregados de la encuesta permiten:

- Construir perfiles de madurez por sector y tamaño.
- Identificar dominios donde la brecha entre discurso y práctica es más sangrante (por ejemplo, mucha política, poca operación).[web:24][web:50]
- Alinear agendas de inversión: qué dominios requieren más atención (SOC, continuidad, gestión de riesgos, etc.).
- Alimentar informes país que dialoguen con índices internacionales (NCSI, GCI) desde una óptica COBIT.[web:28][web:43]

A nivel de organización, la lectura honesta del IGM y de los subíndices por dominio permite pasar de la pregunta “¿estamos bien en ciberseguridad?” a “¿dónde duele más y cuánto estamos dispuestos a invertir en curarlo?”.

6. Cómo leer (y sobrevivir a) los resultados

La tentación habitual es buscar una cifra mágica (“estamos a 3,2 sobre 5, luego vamos bien”). La propuesta aquí es algo más sofisticada:

1. Observar el perfil por dominios COBIT: gobierno, riesgo, seguridad, cambios, servicios, continuidad, monitorización.
2. Identificar asimetrías (por ejemplo, gobierno fuerte con operación débil, o SOC avanzado sin gestión de riesgos formal).
3. Revisar la coherencia con el contexto: sector, criticidad, regulaciones aplicables.
4. Conectar con el portafolio de proyectos e iniciativas: qué proyectos aportan más a cerrar las brechas detectadas.

Lo que la encuesta ofrece no es una nota final, sino un **mapa de discusión** entre tecnología, riesgo y negocio.

7. Epílogo: la ironía como herramienta de gobierno

En ciberseguridad, como en la vida, la autoimagen suele ir por delante de la realidad. Esta encuesta intenta rebajar la distancia con un tono que permita decir cosas serias sin perder el sentido del humor.

Si al completarla descubres que tu organización está menos madura de lo que pensabas, enhorabuena: has ganado claridad. Y si resulta que está mejor de lo esperado, mejor aún: ahora tendrás argumentos para defender las inversiones que te han traído hasta ahí.

En cualquier caso, COBIT seguirá ahí, recordándonos que **lo que no se gobierna no se sostiene, y lo que no se mide no mejora**.^[web:18]^[web:29]